Measuring the Security Posture of IEC 61850 Smart Grid Substations Against Supply Chain Attacks

Onur Duman, Mohsen Ghafouri, *Senior Member, IEEE*, Lingyu Wang, *Member, IEEE*, Marthe Kassouf, Ribal Atallah, *Member, IEEE*, Mourad Debbabi

***Abstract*— Recently, there has been a surge of interest in analyzing and modeling emerging cyberattacks resulting from supply chain vulnerabilities in smart grids. These vulnerabilities are deliberately injected into devices before shipment by a malicious or trustworthy but compromised vendor during supply chain attacks. As a result, those vulnerabilities possess unique characteristics, such as stealthiness. Such characteristics, together with the limited number of vendors, demand new techniques for measuring the security posture of smart grids in the presence of those vulnerabilities. On this basis, this paper first defines a supply chain risk metric (SCR) to measure the risks of different devices containing those vulnerabilities based on several risk factors. Afterward, we enhance the previously defined kSupply metric and propose a new metric, namely kSupplier to include vendors in the risk assessment. Finally, we evaluate the proposed metrics and models through simulations conducted on IEEE 14 and 39-bus systems.**

***Index Terms*— smart grid, security metrics, supply chain.**

I. Introduction

SUBSTATIONS are critical components of the smart grid since they provide monitoring, control, and protection capabilities for the grid [1]. IEC 61850 [2] is a standard that is commonly utilized in substation automation systems for the interoperability of devices from different vendors. In this standard, all functions in a substation are split into sub-functions known as logical nodes. Such a transition makes devices from different vendors interoperable. Even though having the option to choose devices from different vendors in a substation gives flexibility to power system operators, ensuring that each vendor is trustworthy is challenging.

Moreover, due to their relatively higher levels of automation, complexity, and inclusion of devices from different vendors, smart grid substations can become attractive targets for supply chain (hijacking) attacks. The proprietary nature of devices contained inside substations and the limited number of vendors imply that a power utility has little choice but to trust the available vendors, even if such a trust is not completely warranted. To make things worse, even a trustworthy vendor may become the target of those attacks. For instance, the high-profile SolarWinds attack demonstrates the severe consequences of hijacking a vendor's update channel through a supply chain attack [3]. In the SolarWinds case, the attackers injected a backdoor into update channels of Orion Network Management software developed by SolarWinds, allowing attackers to take control of corporate networks utilizing Orion [3]. Even though this attack did not specifically target substations, power grid operators utilizing Orion for network management could face cyber attacks with physical consequences after attackers take control of their networks. In addition, supply chain vulnerabilities possess unique characteristics, such as being continuously updated by the (hijacked) vendor to ensure stealthiness, taking the form of a hidden backdoor, and being specifically designed to cause long-term damages [4]. Therefore, protecting smart grids and substations means more than just patching known vulnerabilities and deploying traditional defense mechanisms (e.g., firewalls). Going beyond those to further evaluate the resilience of those against potential supply chain attacks is of paramount importance.

In the literature, supply chain attacks have attracted only limited attention, particularly in the smart grid domain (a detailed review of related work will be provided in Section IV). Despite existing efforts in analyzing and detecting those attacks, the development of metrics to quantify the risk of those threats is mostly overlooked in the literature. Significant research gaps remain, such as the lack of means for instantiating the proposed security metrics based on various supply chain-related risk factors and the lack of a model for capturing the potential physical consequences of those attacks.

In this paper, we first develop a quantitative risk assessment framework by designing attack graph (AG)-based security metrics for measuring the security postures of substations

The research reported in this paper is supported by the NSERC/Hydro-Québec Thales Research Chair in Smart Grid Security and the NSERC Discovery Grant N01035.

Onur Duman was with Security Research Centre, Gina Cody School of Engineering and Computer Science, Concordia University, H3G 1M8, Montreal, QC, Canada. He is now with the Department of Cyber Security and Networks, Glasgow Caledonian University, G4 0BA, Glasgow, United Kingdom (Onur.Duman@gcu.ac.uk)

Mohsen Ghafouri, Lingyu Wang, and Mourad Debbabi are with the Security Research Centre, Gina Cody School of Engineering and Computer Science, Concordia University, H3G 1M8, Montreal, QC, Canada (mohsen.ghafouri@concordia.ca; wang@ciise.concordia.ca; debbabi@ciise.concordia.ca)

Marthe Kassouf and Ribal Atallah are with Hydro-Quebec Research Inst. (IREQ), J3X 1S1, Varennes, Quebec, Canada (atallah.ribal@hydroquebec.com; kassouf.marthe@hydroquebec.com).

against supply chain attacks. These attack graph-based metrics measure the security posture regarding the minimum number of supply chain vulnerabilities and the minimum number of devices from malicious vendors that must be exploited for compromising substations. Intuitively, a higher value of those metrics would indicate a less vulnerable substation because it is significantly less likely to have many supply chain vulnerabilities or malicious vendors at the same time and in the same substation. After that, to capture the potential physical consequences of supply chain attacks, we develop a technique to identify critical substations from a supply chain attack perspective. In summary, our contributions are as follows.

- Designing a supply chain risk metric, i.e., SCR, to measure the relative risk of vendors and devices for containing supply chain vulnerabilities through quantifying and integrating various supply chain-related risk factors following a methodology inspired by the Common Vulnerability Scoring System (CVSS) [5].
- Redefining the $kSupply$ *metric* proposed in [4] based on the SCR, such that the former can now be instantiated based on concrete risk factors about the supply chain (instead of considering all supply chain vulnerabilities to be identical as in [4]).
- Designing a new metric, $kSupplier$, to capture the case where all the devices from a malicious (or hijacked) vendor may contain supply chain vulnerabilities, and therefore the metric allows operators to evaluate how many malicious vendors (instead of vulnerabilities) the substation can withstand.
- Utilizing attack graphs with Markov Decision Process (MDP) to identify critical substations concerning cybersecurity posture and criticality in terms of potential physical damages.

In the following, we present a motivating example to highlight further the need for a quantitative security assessment framework for power systems against supply chain attacks.

A. Motivating Example

Consider the substation configuration (detailed in [6]) in Fig. 1. Assume that this substation configuration corresponds to Bus 1 of IEEE 4-bus [7] also shown in Fig. 1. Also, assume that a cyber adversary incapable of exploiting supply chain vulnerabilities (Node 100 in Fig. 1) has remote access to the substation network. In order to compromise the substation and start tripping circuit breakers remotely, the adversary needs to follow the attack path, which includes (in the given order) compromising the gateway (Node 6), the Human Machine Interface (HMI, Node 1), the Workstation (Node 2), and protection IEDs (Nodes 7 and 19). However, on the contrary, an attacker who is capable of exploiting supply chain vulnerabilities (Node 101) can compromise the update channels of the IEDs both of which come from the same vendor, namely $Supplier1$. This attacker can inject one autonomous supply chain vulnerability in Node 7 that leaks critical information (such as configuration files [2]) through covert channels [4]. In addition, the same attacker (Node 101) can inject a backdoor [8] into Node 19 that allows

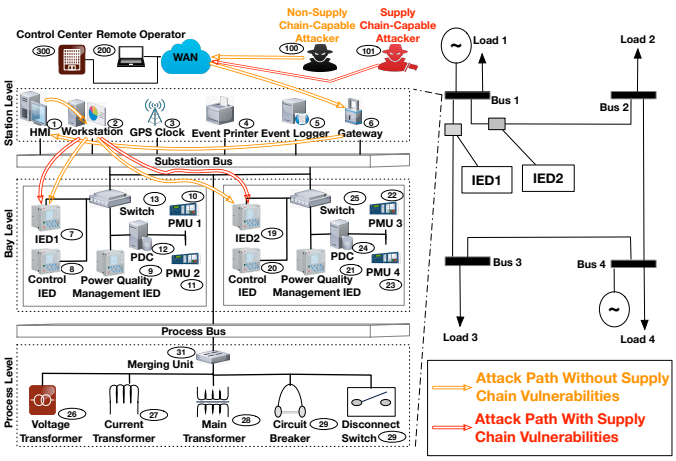


Fig. 1: Motivating Example Including the Smart Grid Substation Based on IEC 61850-90-4 [4] (Left) and IEEE 4-Bus System [7] (Right)

the attacker to send malicious trip commands from Node 19 after compromising the substation network. This example demonstrates that supply chain vulnerabilities can make the compromise easier for attackers capable of exploiting them (e.g., Node 101 in Fig. 2).

In order to model those attacks and develop security metrics, we extend the widely used AG model [9], [10] which are visual models used to model different ways critical systems, such substations, can be attacked through actions taken by the attacker (e.g., vulnerability exploits). AG model is developed based on the set of hosts, the set of connections between hosts, and the set of vulnerabilities in each host. Attack graphs consider dependencies between vulnerabilities rather than just considering each vulnerability in hosts in isolation. Those models are commonly used in the literature to develop quantitative security metrics (e.g. $k0d$ [11], $kSupply$ [4]) or to identify ways to systematically harden critical systems (e.g., [12]). A typical AG consists of two types of nodes which are exploits and conditions. To illustrate, Fig. 2 shows an AG in which white, light grey, and grey nodes indicate known, zero-day, and supply chain vulnerabilities, respectively (the supply chain risk score and the probabilities can be ignored for now and will be explained later in Section II.A of the paper). In this AG, conditions (such as $\langle GW, 6\rangle$) are shown between angle brackets, which can indicate the connectivity (e.g., $\langle 6, 1\rangle$), the existence of a service in a host (e.g., $\langle HTTP, 2\rangle$), or a privilege gained by the attacker (e.g., $\langle root, 2\rangle$). If the attacker is capable of exploiting known and zero-day vulnerabilities (such as Node 100 in Fig. 1), the attacker can follow the attack path: $\langle V_Known_1, Attacker, 6\rangle \rightarrow \langle V_Known_2, 6, 1\rangle \rightarrow \langle V_SCADA, 1, 2\rangle \rightarrow \langle V_Trip, 2, 19\rangle$. However, a supply chain capable attacker (such as Node 101 in Fig. 1), does not need to exploit the vulnerability $\langle V_Trip, 2, 19\rangle$ to compromise Node 19. Instead, the attacker can utilize a supply chain vulnerability in Node 19 planted by the attacker, namely $\langle V_SupplyChain_2, 19, 19\rangle$. Lastly, the $Intermediate$ node is utilized to demonstrate the fact that the attacker can compromise either IED1 (Node 7 in Fig. 1) for information disclosure or IED2 (Node 19 in Fig. 1) for being able to send malicious trip commands by tampering with Generic Object Oriented Substation Event (GOOSE) messages [13]. The AG model motivates us to ask the following questions: *How can we model*

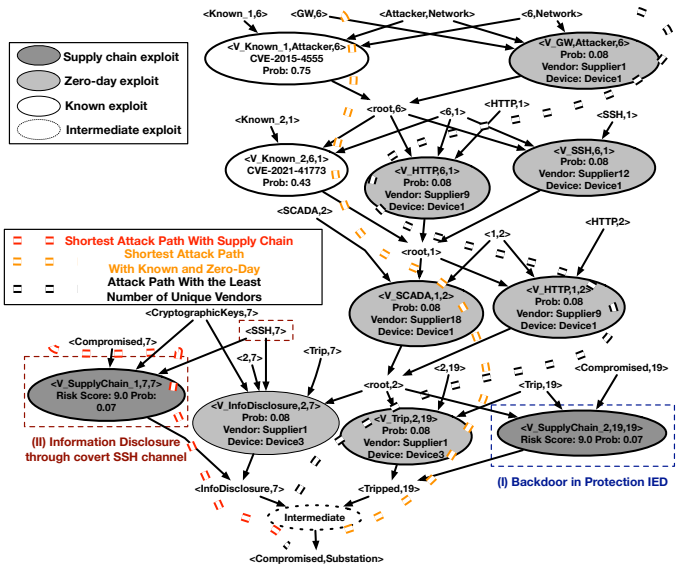


Fig. 2: AG Showing Attack Paths: A) Information Disclosure (II) Using One Supply Chain Exploit (Red), B) Compromising Node 19 to Send Malicious Trip Commands Using Known and Zero-Day Only (Orange), C) Attack Path Containing the Minimum Number of Unique Vendors (Black)

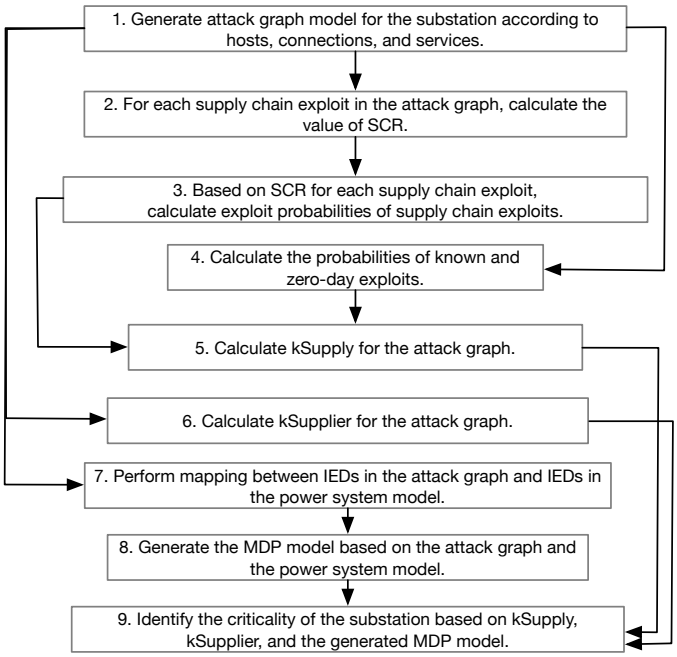


Fig. 3: Overview Figure for Calculating Supply Chain Security Metrics

the likelihood that each device contains a supply chain vulnerability? How can we measure the overall security posture of this substation against potential supply chain attacks? How can we capture the physical consequences of such supply chain attacks, e.g., tripping circuit breakers? The remainder of this paper will answer those research questions by developing a series of security metrics.

II. Supply Chain Security Metrics

After building the AG model, the next step is to define attack graph-based security metrics. Each host can contain one or more of three types of vulnerabilities: known, zero-day, and supply chain. For the hosts containing supply chain vulnerabilities, a supply chain risk score (SCR) is assigned to each supply chain vulnerability and probabilities of exploiting each supply chain vulnerability are calculated (Section II-A). SCR is a CVSS-inspired metric that aims to measure the risk of supply chain vulnerabilities based on several risk factors. A higher value of SCR means that the supply chain vulnerability contained inside the device is more risky since it implies a high risk for several risk factors. After that, probabilities of known and zero-day vulnerabilities are also calculated, and then the $kSupply$ [4] security metric is calculated based on all those probabilities (Section II-B). $kSupply$ is an attack graph-based security metric that aims to measure the security postures of substations with respect to the number of supply chain vulnerabilities the attacker needs to exploit. A higher value of $kSupply$ means a better security posture against supply chain attacks since it is not likely for many different supply chain vulnerabilities to exist in the same substation and to be exploitable by the same attacker. Consequently, the $kSupplier$ security metric, which assumes that all vendors are untrustworthy and calculates how many such vendors the substation can withstand, is calculated (Section II-C). $kSupplier$ is another attack graph-based security metric that aims to measure the number of malicious vendors a smart grid substation can withstand. A higher value of $kSupplier$ means a better security posture against supply chain attacks since it is not likely for many devices from different vendors to contain supply chain vulnerabilities and to be exploitable by the same attacker. After calculating those metrics, an MDP model is generated to identify critical hosts in terms of potential physical damage (Section II-D). At the end of those steps, we get three values which are the $kSupply$ metric for the substation, $kSupplier$ metric for the substation, and the criticality of the substation in terms of potential physical damage (Section II-E). Fig. 3 shows the steps for calculating supply chain security metrics and dependencies between each step. Those steps are explained in the remainder of this section.

A. Supply Chain Risk Score (SCR)

1) Background on Supply Chain Risk Score: A substation network may include devices from different vendors, and one malicious vendor may cause up to 14 compromised devices, as shown by the authors in [4]. Although it is typically assumed that all those vendors are trustworthy, this may not always be the case. In order to measure the severity of supply chain vulnerabilities, we define the SCR inspired by the CVSS [5]. SCR is defined similarly to CVSS to take lessons from CVSS. For instance, CVSS has an important feature, which is hierarchical scoring. Hierarchical scoring in CVSS means that the base score is first calculated; then, temporal and environmental scores are calculated if (and only if) the necessary information is available. Hierarchical scoring is also applicable in the case of supply chain vulnerabilities since there are risk factors [12] that can be quantified easily, such as the existence of vendors in the Open Trusted Technology Forum [14]. On the contrary, some risk factors [12] may not be quantified easily, such as secure transportation of devices.

In addition, risk factors such as outsourcing may be kept confidential. Therefore, we also define the SCR hierarchically such that all the available risk factors can be identified and combined into a metric.

SCR is a supply chain risk scoring methodology that is inspired by CVSS. CVSS is commonly used for scoring severities of known vulnerabilities based on several factors, such as exploitability. In addition, CVSS is widely used in the AG-based security metrics literature (e.g., [15], [6]) for estimating probabilities of exploiting known vulnerabilities. However, CVSS does not cover supply chain-specific risk factors. In this regard, we aim to define a scoring framework for supply chain vulnerabilities similar to CVSS. For this purpose, we first categorize questions related to supply chain security in the NIST document [16] Table D-13 under several risk factors. After that, we identify the number of possible values for each risk factor from HIGH to LOW based on answers to questions related to the risk factor in Table D-13 of the NIST document. Consequently, we map that risk factor to a sub-metric in CVSS with the same number of possible values. For example, according to Table D-13 in the NIST document [16], there are two questions related to the risk factor Producer of the Product (P). The number of YES answers to those questions can be 0, 1, or 2. This implies that this risk factor can have three possible values. In CVSS, the sub-metric "Privileges Required" can also take 3 values. Therefore, we map the risk factor Producer of the Product (P) to "Privileges Required" sub-metric in CVSS for assigning numerical for each possible value of the risk factor. Other risk factors are quantified in a similar manner. Moreover, the CVSS score measures severities of known vulnerabilities based on three types of metrics which are base, temporal, and environmental. Base metrics define characteristics of vulnerabilities that do not change over time. Temporal metrics are based on factors that change over time. Environmental metrics adjust the base and temporal metrics to a specific computing environment. In SCR, we categorize risk factors as base and temporal so that SCR can be calculated without knowledge of some risk factors as some risk factors may be hard to quantify, such as Outsourcing. By taking all those into account, we utilize CVSS for assigning numerical values for possible values risk factors can take to develop a risk scoring framework that is similar to CVSS for supply chain vulnerabilities. We evaluate SCR by assigning different values to risk factors in Section III through Simulations. Risk factors, along with their categories and mapping, are described in the next section.

2) Risk Factors for Supply Chain Vulnerabilities:

Origin of the Product (O): The country in which the device is produced may be trusted or distrusted. Since the manufacturer's origin is assumed to be known in most cases, this risk factor is considered in the base score. Questions from the NIST SP-800 [16] related to this risk factor are: a) Table D-13, Sect. 2, Qn. 3 from [16] related to geopolitical risk. b) Table D-13, Sect. 2, Qn. 4 from [16] related to the country of special concern. c) Table D-13, Sect. 3, Qn. 7 from [16] related to laws and regulations of the foreign country. This risk factor is mapped to the "Attack Vector" base metric in CVSS, which also has 4 possible values: NETWORK (0.85), ADJACENT (0.62), LOCAL (0.55), PHYSICAL (0.20). Based on this, the risk factor **O** for a given device (De) is HIGH (0.85) for 3, MEDIUM HIGH (0.62) for 2, MEDIUM LOW (0.55) for 1, and LOW (0.20) for 0 YES answers.

Producer of the Product (P): This risk factor depends on the producer of the device. This risk factor is included in the base score, assuming the vendor is known. Questions from the NIST SP-800 [16] related to this risk factor are a) Table D-13, Sect. 3, Qn. 11 from [16] related to tracking part numbers. b) Table D-13, Sect. 3, Qn. 18 from [16] related to secure maintenance. This risk factor is mapped to the "Privileges Required" base metric in CVSS, which has the following 3 possible values: NONE (0.85), LOW (0.62), HIGH (0.27). Based on this, the risk factor **P** for a given device De is HIGH (0.85) for 0, MEDIUM (0.62) for 1, and LOW (0.20) for 2 YES answers.

Inclusion of the Vendor in Open Group Trusted Technology Forum (OTT): The Open Group Trusted Technology Forum (OTTF) [14] develops a global supply chain integrity procedure that provides buyers with a choice of certified partners and vendors. Given the fact that the involvement of the producer in OTTF can be verified from the official website [14], this risk factor is included in the base score. This risk factor can take two possible values, which are: AVAILABLE and NOT AVAILABLE. Therefore, we adopt the scoring of "Attack Complexity" base metric in CVSS [5], which has 2 possible values: LOW (0.77) and HIGH (0.44). Based on this, the risk factor **OTT** for a given device De is AVAILABLE (0.44) when the vendor is included and NOT AVAILABLE (0.77) when the vendor is not included in OTTF.

Transparency of Supply Chain Best Practices (BP): This risk factor measures the level of transparency of the vendor in terms of applying supply chain best practices. Since such transparency is assumed to be known in most cases, this risk factor is included in the base score. Questions from the NIST SP-800 [16] related to this risk factor are: a) Table D-13, Sect. 4, Qn. 7 from [16] related to risk mitigation activities. b) Table D-13, Sect. 3, Qn. 10 from [16] related to threat scenarios. c) Table D-13, Sect. 3, Qn. 16 from [16] related to industry standard baselines. Similar to the risk factor **O**, this risk factor is mapped to "Attack Vector" in CVSS since they both have 4 possible values.

Usage of Modules From Other Vendors (UV): This risk factor aims to measure the risk related to parts from other vendors used by the vendor. This risk factor is placed in the temporal score since a vendor can utilize parts from different vendors at different times. Questions from the NIST SP-800 [16] related to this risk factor are: a) Table D-13, Section 3, Qn. 1 from [16] related to critical suppliers. b) Table D-13, Section 3, Qn. 8 from [16] related to replacement components. c) Table D-13, Section 3, Qn. 12 from [16] related procurement. This risk factor is mapped to "Exploit Code Maturity" in CVSS [5], which is listed as a temporal metric having 4 possible unique values (NOT DEFINED and HIGH have the same value 1.0): HIGH (1.00), FUNCTIONAL (0.97), PROOF OF CONCEPT (0.94), UNPROVEN (0.91). Even though there are other temporal CVSS metrics with 4 possible unique values, Exploit Code Maturity was chosen for mapping since it has

TABLE I: Supply Chain Risk Factors [12]

Risk Factor	Category	Possible Values	Relevant Questions from Table D-13 in [16]	Accounts for the complexity and interdependencies of devices
Origin of the Product (O)	BASE SCORE	HIGH: 0.85, MEDIUM HIGH: 0.62, MEDIUM LOW: 0.55, LOW: 0.20	- Sect. 2, Qn. 3 - Sect. 2, Qn. 4 - Sect. 3, Qn. 7	NO
Producer of the Product (P)		HIGH: 0.85,MEDIUM: 0.62, LOW: 0.27	- Sect. 3, Qn. 11 - Sect. 3, Qn. 18	NO
Inclusion of the Product in Open Group Trusted Technology Forum (OTT)		AVAILABLE: 0.44, NOT AVAILABLE: 0.77	N/A	NO
Transparency of Supply Chain Best Practices (BP)		HIGH: 0.85, MEDIUM HIGH: 0.62, MEDIUM LOW: 0.55, LOW: 0.20	- Sect. 4, Qn. 7 - Sect. 3, Qn. 10 - Sect. 3, Qn. 16	YES
Usage of Modules From Other Vendors (UV)	TEMPORAL SCORE	HIGH: 1.0, MEDIUM HIGH: 0.97, MEDIUM LOW: 0.94, LOW: 0.91	- Section 3, Qn. 1 - Section 3, Qn. 8 - Section 3, Qn. 12	YES
Outsourcing During Production (OU)		HIGH: 1.0, MEDIUM : 0.97, LOW: 0.91	- Section 3, Qn. 9 - Section 4, Qn. 1	YES
Secure Transportation of the Product (ST)		HIGH: 1.0, MEDIUM HIGH: 0.97, MEDIUM LOW: 0.94, LOW: 0.91	- Section 5, Qn. 2 - Section 5, Qn. 6 - Section 5, Qn. 8	NO

the highest range of numeric values (from 0.91 to 1.0). Based on this, the risk factor **UV** for a given device De is HIGH (1.00) for 0, MEDIUM HIGH (0.97) for 1, MEDIUM LOW (0.94) for 2, and LOW (0.91) for 3 YES answers.

Outsourcing During Production (OU): Outsourcing is the usage of resources of another company during product development. It is considered in temporal score since companies to which the vendor outsources may change with time. Quantifying the level at which outsourcing is done in a trusted manner is challenging. The quantification of outsourcing shows how much the end user trusts the vendor in the way the vendor performs outsourcing. Questions from the NIST SP-800 [16] related to this risk factor are: a) Table D-13, Section 3, Qn. 9 from [16] related to owners and locations of subcontractors. b) Table D-13, Section 4, Qn. 1 from [16] related to definitive policies and procedures. This risk factor is mapped to "Report Confidence" in CVSS [5], which is listed as a temporal metric having 3 possible unique values (NOT DEFINED and CONFIRMED have the same value 1.0): CONFIRMED (1.00), REASONABLE (0.96), and UNKNOWN (0.92). Based on this, the risk factor **OU** for a given device De is HIGH (1.00) for 0, MEDIUM (0.97) for 1, and LOW (0.91) for 2 YES answers.

Secure Transportation of the Product (ST): Secure transportation means that the product is not tampered with during transportation. Even if the vendor follows supply chain best practices, supply chain vulnerabilities may be inserted into products during transportation. Secure transportation is considered a temporal risk metric since its value can change with time. Questions from the NIST SP-800 [16] related to this risk factor are: a) Table D-13, Section 5, Qn. 2 from [16] related to events that can interrupt the supply chain. b) Table D-13, Section 5, Qn. 6 from [16] related to tampering. c) Table D-13, Section 5, Qn. 8 from [16] related to deployment. Similar to the risk factor **UV**, this risk factor is also mapped to "Exploit Code Maturity" in CVSS [5].

3) Defining the Supply Chain Risk Score (SCR): After defining risk factors (as summarized in Table I), the next step is to combine them into the base and temporal scores for defining the mathematical formulation of SCR. We do this in a similar way as the exploitability base score of CVSS [5], which is defined as:

$$E = 8.22 \times AV \times AC \times PR \times UI \tag{1}$$

where E is *Exploitability*, AV is *Attack Vector*, AC is *Attack Complexity*, PR is *Privileges Required*, UI is *User Interaction*. Here the constant 8.22 is used to ensure that the base metric values are in the proper range (from 0.0 to 10.0) in CVSS [5]. Similarly, in the developed SCR, we use the constant 32.315 to make sure base metric values are within a proper range. Similar to the CVSS exploitability score, the supply chain base metric ($SCRB$) is defined as:

$$SCRB = 32.315 \times O \times P \times OTT \times BP \tag{2}$$

Additionally, the supply chain risk temporal score ($SCRT$) is defined as follows:

$$SCRT = SCRB \times UV \times OU \times ST \tag{3}$$

After defining $SCRB$ and $SCRT$, SCR for a given device De is formally defined as:

$$SCR(De) = \begin{cases} SCRB & \text{If factors UV, OU, and ST are not available.} \\ SCRT & \text{If factors UV, OU, and ST are available.} \end{cases}$$

After defining the SCR, the next step is to define the probability of exploiting a supply chain vulnerability. The probability is 1.0 for the attacker behind that supply chain vulnerability. For others, since supply chain vulnerabilities are designed to be stealthy, the probability of exploiting a supply chain vulnerability should be as difficult as even more difficult than exploiting a zero-day vulnerability. Based on those, the probability of exploiting a given supply chain exploit in a given device De ($Pr(De)$) is 1.0 for the attacker behind that supply chain vulnerability and $0.08 \times \frac{SCR(De)}{10.0}$ for all other attackers. Since exploiting a supply chain vulnerability is at least as difficult as exploiting a zero-day one—with the probability

of 0.08 [17]—we used 0.08 coefficient in $Pr(SE)$ to ensure the proper range of $Pr(SE)$, i.e., between 0.00 and 0.08 for attackers not behind the vulnerability.

Moreover, in order to differentiate between the difficulties of exploiting different vulnerabilities, the associated probability is converted to the path length using the approach detailed in [6]. For instance, in Fig. 2, the probability of exploiting the supply chain vulnerability ($\langle V_SupplyChain_1, 2, 2\rangle$) is $0.08 \times 0.9 = 0.07$. Thus, the path length of exploiting that vulnerability is $log_{0.08}0.07 = 1.05$, which means it takes 1.05 times more effort compared to a zero-day vulnerability to exploit that supply chain vulnerability. Next, we leverage the supply chain exploit probabilities, which are calculated using SCR, to enhance the $kSupply$ metric defined in [4].

B. Extending the kSupply [4] Security Metric

$kSupply$ metric (inspired by the $k0d$ metric [11]) is defined by the authors in [4]. $k0d$ counts the minimum number of distinct zero-day vulnerabilities required to compromise a critical asset in a given network. Similarly, $kSupply$ [4] counts the minimum number of distinct supply chain vulnerabilities (note that if an attacker is capable of exploiting supply chain vulnerabilities, the same attacker is assumed to be capable of exploiting zero-day and known vulnerabilities as well) in order to compromise the network. However, the $kSupply$ metric presented in [4] makes the unrealistic assumption that all supply chain vulnerabilities are equivalent, which neglects the impact of vendors. In this paper, we integrate $kSupply$ with the SCR to overcome this limitation. For example, in Fig. 2, the value of $kSupply$ is 1 according to the $kSupply$ metric defined in [4] since the supply chain capable attacker needs to take advantage of $\langle V_SupplyChain_1, 7, 7\rangle$ in order to cause IED1 (Node 7 in Fig. 1) to leak information. However, this supply chain exploit has a risk score of 9.0, therefore the exploit probability of 0.07 which leads to the path length of 1.05 as described in the previous paragraph. Therefore, the value of $kSupply$ is 1.05 in the extended definition. Here is the mathematical formulation of the extended $kSupply$ metric:

Definition I: For an attack graph G with n attack paths $P_1, \cdots, P_n$, we extend $kSupply$ [4] metric for an attack path P_i, starting from initial conditions and ending in the goal condition, as $kSupply(P_i) = \sum_{j=1}^{N} log_{0.08}SProb(j, P)$. In this equation, $SProb(j, P)$ is the probability of exploiting the vulnerability j on the attack path P_i, which is 0.08 for zero-day [17], $\frac{CVSSScore}{10.0}$ for known [6], and $PrSE$ for supply chain vulnerabilities. $kSupply$ for a given attack graph G is calculated by taking the minimum among $kSupply$ values of all attack paths. $kSupply(G) = \min_{\forall t=1,\cdots,n}(kSupply(P_t))$.

C. kSupplier Security Metric

After defining the extended $kSupply$ metric which makes the distinction between supply chain vulnerabilities, we define another security metric for the worst-case scenario in which all vendors are assumed to be malicious. In this regard, we develop the $kSupplier$ metric which makes such an assumption to count the minimum number of unique vendors that need to be targeted by the attacker to compromise the substation. For instance, in Fig. 2, the shortest attack path with the minimum number of distinct vendors (shown in black) contains 2 distinct vendors: "Supplier 1" and "Supplier 9". Thus, the value of $kSupplier$ is 2 for the attack graph in Fig. 2. Here is the mathematical formulation of the extended $kSupplier$ metric:

Definition II: For a given attack graph A with n distinct attack paths $P_1, \cdots, P_n$, let an attack path P_i contain k exploits $E_1, \cdots E_k$. Let V be the set of distinct vendors on an attack path P_i. $V(P_i) = \bigcup_{i=1}^{k}\{Vendor(E_i)\}$, where $Vendor(E_i)$ gives the vendor for a given exploit E_i. $kSupplier(A) = \min_{\forall t=1,\cdots,n} \mathbf{card}(V(P_t))$, where $P_t, t = 1, \cdots, n$ represents attack paths on A, and $\mathbf{card}$ is the set cardinality function.

We consider an unknown vendor as a "Unknown" which would match any other vendor, and hence unknown vendors on a path will not increase the value of $kSupplier$ metric, and a path including only unknown vendors always has the $kSupplier$ value of 1. As we demonstrate through simulations in Section III, $kSupplier$ and $kSupply$ complement each other in the sense that $kSupply$ can be used for the cases in which $kSupplier$ cannot be improved.

D. MDP Generation Based on Attack Graph

In addition to finding the shortest attack path for compromising critical hosts in networks, attack graphs can also be utilized for calculating probabilities of compromising each host by converting them into Bayesian networks (as detailed in [15] and [6]). However, attack graphs do not consider the physical damage the attacker can cause to power systems. In order to overcome this limitation, the authors in [18], [19] utilize the MDP model in which the attacker is modeled as an agent aiming to maximize the amount of physical damage to the power system for finding critical states the attacker can visit but in both of those works probabilities are calculated without considering exploit relationships.

An MDP consists of the following: S is a finite set of states, A is the finite set of actions, $P(s, s', a)$ is the transition probability function, $R(s')$ is the reward function for the state s', and $\gamma \in$ [0,1] is the discount factor [20]. In order to generate the MDP model from the AG, the first step is to identify the set of states and the set of connections between those states. States (S) are sets of hosts compromised by the attacker in the substation. Actions (A) are vulnerability exploits. Algorithm 1 provides the algorithm for generating MDP for a given AG.

The first step is to add the empty state, which is the starting state of the attacker, to the MDP model (Line 3). After that, the MDP model is updated by getting leaf nodes (Line 5) and finding hosts directly reachable from the last hosts in leaf nodes (Line 7 when the leaf node is the initial condition and Line 17 when the leaf node contains a set of hosts). Consequently, new states are created based on reachable hosts (Line 9 for the initial and Line 19 when the leaf node contains states) and state transitions are added (Line 10 for the initial and Line 20 when the leaf node contains states). This process continues until no states can be added to the MDP (Line 4).

State transition probabilities ($P(s, s', a)$) are retrieved from the attack graph by converting it to a Bayesian model and

Algorithm 1 Generating MDP For a Given Attack Graph

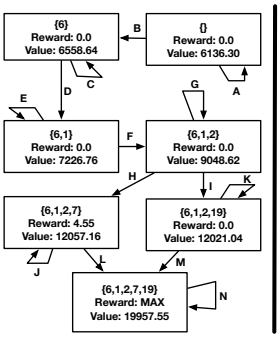
Input: Attack graph connectivity conditions ($Conn$), and goal host (h_g).
Output: MDP model generated from the attack graph.
- Add the initial state $\{\}$ in which no hosts are compromised to the MDP
while No more states can be added **do**
    - Get leaf nodes of the MDP
    if the leaf node is the initial state ($\{\}$) **then**
        - Find hosts h_i, where $< h_i, Network > \epsilon\ Conn$
        for each host h_i **do**
            - Add state $\{h_i\}$ to the MDP
            - Create transition from $\{\}$ to $\{h_i\}$.
    else
        for each leaf node **do**
            if the leaf node contains the goal host, h_g **then**
                - Do not add any more states
            else
                - Let $\{h_1, h_2, \cdots, h_{k-1}, h_k\}$ be the leaf node
                - Find hosts h_i, for which $< h_k, h_i > \epsilon\ Conn$ in the attack graph,
                for Each host h_i **do**
                    - Add state $\{h_1, h_2, \cdots, h_{k-1}, h_k, h_i\}$ to MDP
                    - Add transition from $\{h_1, h_2, \cdots, h_{k-1}, h_k\}$ to $\{h_1, h_2, \cdots, h_{k-1}, h_k, h_i\}$

performing inference on each privilege condition. For example, edge D in Fig. 4 is the probability that the attacker can compromise HMI (Node 1 in Fig. 1) given that the attacker has already compromised the gateway (Node 6 in Fig. 1). As a rule for an MDP model, the sum of probabilities of outgoing edges from one state should be equal to 1.0. A vulnerability exploit can either go to the next state (adding one more host to the set of compromised hosts) or stay in the same state (which means the attacker has failed at that attack stage).

The reward function is defined as the sum of overload percentages of transmission lines [18] after tripping a breaker. In pandapower [21], an open source power system simulator, transmission line failures can be simulated, and load percentages can be retrieved. The reward function is defined as the sum of loads exceeding the line capacity. As an example, if IED1 in Fig. 1 trips the transmission line between Bus1 and Bus2, load percentages for all other transmission lines are 57.60%, 41.80%, and 104.55% according to pandapower [21]. In this case, the amount of the reward is 4.55. If both IED1 and IED2 trip, it causes a blackout, so the reward is maximum.

The discount factor shows the difference between getting a reward immediately or in the future. In [19], the authors experiment with different discount factors. In this paper, the discount factor is taken as constant 0.95 (a constant value close to 1.0) in order to make the value iteration algorithm converge [20]. After defining the MDP, the value iteration function is executed for the MDP to identify state values.

Fig. 4 shows the MDP for the attack graph in Fig. 1.



A: Pr(<root,6> | {})' = 0.23
B: Pr(<root,6> | {}) = 0.77
C: Pr(<root,1> | {<root,6>})' = 0.48
D: Pr(<root,1> | {<root,6>}) = 0.52
E: Pr(<root,2> | {<root,6>,<root,1>})' = 0.79
F: Pr(<root,2> | {<root,6>,<root,1>}) = 0.21
G: Pr(<Tripped,7> | {<root,6>,<root,1>,<root,2>})' + Pr(<Tripped,19> | {<root,6>,<root,1>,<root,2>})' = 0.84
H: Pr(<Tripped,7> | {<root,6>,<root,1>,<root,2>}) =0.08
I: Pr(<Tripped,19> | {<root,6>,<root,1>,<root,2>}) =0.08
J: Pr (<Tripped,19> | {<root,6>, <root,1>, <root,2>, <Tripped,7>})' = 0.92
K: Pr (<Tripped,7> | {<root,6>, <root,1>, <root,2>, <Tripped,19>})' = 0.92
L: Pr (<Tripped,19> | {<root,6>, <root,1>, <root,2>, <Tripped,7>}) = 0.08
M: Pr (<Tripped,7> | {<root,6>, <root,1>, <root,2>, <Tripped,19>}) = 0.08
N: Pr (<Compromised,Substation> | {<root,6>, <root,1>, <root,2>, <Tripped,7>,<Tripped,19>}) = 0.08

Fig. 4: MDP For The Attack Graph in Fig. 2 (left) and Transition Probabilities (right)

According to this model, if the attacker has a choice between compromising IED1 (Node 7 in Fig. 1) or IED2 (Node 19 in Fig. 1), the attacker is more likely to choose IED1 since the value of the state in which IED1 is compromised (state $\{6, 1, 2, 7\}$ in Fig. 4) is more than the value of the state in which IED2 is compromised (state $\{6, 1, 2, 19\}$ in Fig. 4). As it can be seen, even though attacking each IED takes the same effort according to the $kSupply$ metric, their physical impacts are different, i.e., compromising IED2 causes more damage than compromising IED1.

E. Identifying Critical Substations

After generating attack graphs and MDPs for each substation, $kSupply$, and $kSupplier$ metrics are calculated. After that, the maximum state value is taken from each MDP model. More formally, for a power system with n substations, the criticality of each substation S_i, $i = 1, \cdots, n$ is a 3-tuple $(kSupply_i, kSupplier_i, max(St_i))$, where St_i is the set of state values [20] for the MDP model generated for S_i. For two substations S_i and S_j, S_i is more critical than S_j if and only if $kSupply_i \leq kSupply_j$ and $kSupplier_i \leq kSupplier_j$ and $max(St_i)) \geq max(St_j))$. Finally, the Pareto front of critical substations is provided to the operator so that those substations can be the focus of security efforts. As an example, the 3-tuple for the substation in Fig. 1 is $(2.05, 2.00, 19957.55)$.

III. Simulations

Simulations for evaluating the effectiveness of $kSupply$ and $kSupplier$ and the scalability of the MDP model are conducted on MacOS Big Sur 11.2 with a 2.4 GHz $i7$ processor and 16 GB of memory. In those simulations, we rely on the well-known formal properties of attack graph analysis in terms of soundness and completeness [10], [22]. Our simulations aim to answer the following research questions: *How effective are the extended $kSupply$ and $kSupplier$ metrics in terms of measuring security postures of IEC 61850 substations against supply chain-capable attackers?*, *How the extended $kSupply$ and $kSupplier$ metrics complement each other?*, *How does the security posture of substations get impacted by the number of information leakage channels and the number of backdoors in protection IEDs?*, *How does SCR behave under different scenarios?*, *How scalable are AGs and MDPs?*, *What are possibly critical substations in IEEE 14 and 39-Bus systems according to designed metrics?*

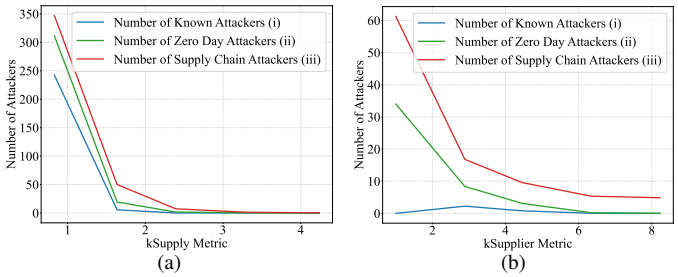


Fig. 5: Effectiveness Simulations (a) $kSupply$ (b) $kSupplier$

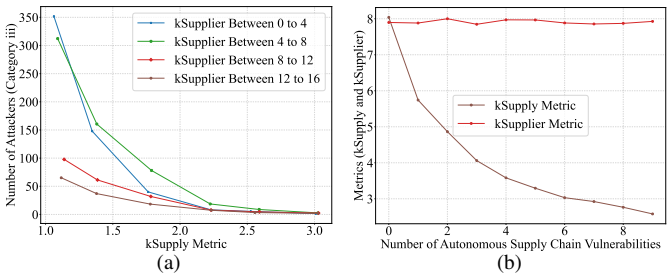


Fig. 6: Relationship Between Metrics (a) $kSupply$ for different $kSupplier$ (b) Number of Autonomous Supply Chain Vulnerabilities vs. Metrics

A. *Effectiveness Evaluation of* kSupply *and* kSupplier

To test the effectiveness of $kSupply$ and $kSupplier$, we generate 4800 AGs are generated using the AG given in Fig. 2 as the seed graph and adding new hosts and new exploits (known, zero-day, and supply chain) in order to ensure that AGs are diverse in terms of size and vulnerabilities. After generating those AGs, the next step is to find relationships between metrics and number of attackers that are capable of exploiting the following types of vulnerabilities: (I) only known, (II) known and zero-day, and (III) known, zero-day, and supply chain.

Results and Implications: As it can be seen in Fig. 5a, the number of category (I) attackers decreases quickly as $kSupply$ increases. After 1.7, only a negligible number of attackers of the category (I) can succeed. The number of category (II) attackers also decreases sharply, and after 2.4, only a negligible number of them can succeed. For category (III) attackers, after 2.5, only a small number of them can succeed. These results verify the correlation between $kSupply$ and the number of category (III) attackers who can succeed. In addition, as it can be seen in Fig. 5b, the $kSupplier$ metric also represents the difficulty of compromising the network for three categories of attackers. Category (I) attackers become a negligible issue after $kSupplier$ value of 5 and $kSupplier$ is not as effective as $kSupply$ in terms of measuring the security posture against those attackers. The number of category (II) attackers becomes negligible after the value of 6. The number of category (III) attackers who can succeed becomes less, but it does not become negligible even with $kSupplier$ value 7. These results demonstrate that both $kSupply$ and $kSupplier$ metrics are effective in terms of measuring the security postures of substations against supply chain attacks since there are correlations between those metrics and the number of successful attackers. $kSupply$ is effective for all types of attackers and even a small increase in $kSupply$ leads to a stronger security posture. On the contrary, $kSupplier$ is effective for attackers of type (ii) and (iii) and an increase in $kSupplier$ improves the security posture slower compared to $kSupply$. This demonstrates that diversifying vendors in attack paths can lead to improved security but is not as effective as different ways to improve $kSupply$ such as reducing SCR for existing supply chain vulnerabilities.

B. *Relationship Between* kSupply *and* kSupplier

This simulation aims to determine how $kSupply$ and $kSupplier$ metrics behave differently and how the number of autonomous supply chain vulnerabilities impact those metrics. A utility may be bound to a limited number of vendors, so it may not always be possible to increase $kSupplier$ easily. Therefore, in this simulation, we first aim to analyze the relationship between $kSupply$ and the number of category (III) attackers for similar $kSupplier$ values. After that, we aim to analyze how those metrics behave with respect to the number of autonomous supply chain vulnerabilities.

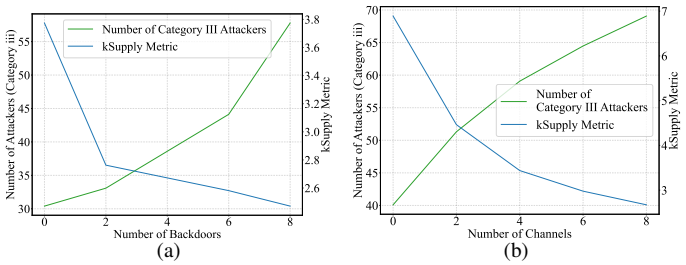


Fig. 7: (a) Number of Backdoors Simulation (b) Number of Channels Simulation

Results and Implications: As it can be seen in Fig. 6a, even when the operator is bound to a limited number of vendors, they can eliminate the majority of attackers by increasing $kSupply$. After $kSupply$ value of around 2.5, category (III) attackers become negligible even for small $kSupplier$ values. In addition, as it can be seen from the blue line in Fig. 6a, for small $kSupplier$ values, the impact of $kSupply$ on the security posture improvement is fast. These results imply that in cases where $kSupplier$ cannot be improved (such as not being able to diversify vendors), $kSupply$ can be utilized. In addition, as it can be seen in Fig. 6b, $kSupplier$ is not effective in measuring the security posture when there are autonomous supply chain vulnerabilities. However, $kSupply$ is effective in that regard since a low $kSupply$ may mean many autonomous supply chain vulnerabilities. These results imply that in cases where $kSupplier$ cannot be improved (such as not being able to diversify vendors), $kSupply$ can be utilized.

C. *Information Leakage Channels and Backdoors*

This simulation aims to determine how the number of information leakage channels and the number of backdoors which are discussed in the motivating example in Fig. 2 impact metrics and attackers. For this simulation, we generate 6000 AGs using the AG in Fig. 2 as the seed graph and randomly add new leakage channels and new backdoors to existing hosts.

Results and Implications: As it can be seen in Fig. 7a Fig. 7b and as the number of backdoors or the number of channels

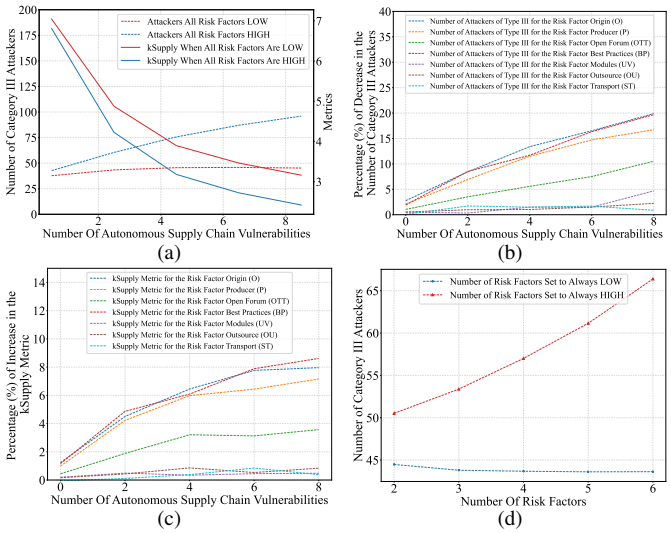


Fig. 8: (Robustness Simulations (a) All Risk Factors are HIGH, LOW (b) Percentage of Decrease in the Number of Attackers from HIGH to LOW (c) Percentage of Increase in $kSupply$ from HIGH to LOW (d) Number of Risk Factors Set to HIGH, LOW and the Number of Attackers

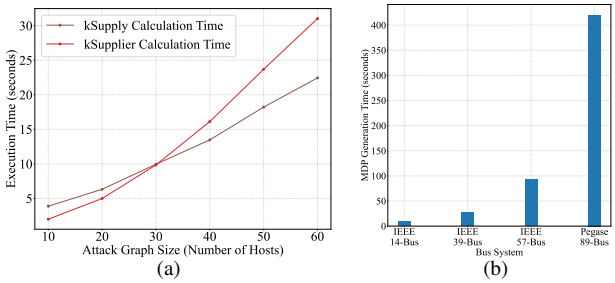


Fig. 9: (a) Metric Calculation Times (b) MDP Generation Times

increases, $kSupply$ decreases and the number of successful attackers increases. The increase is exponential in the case of the number of backdoors which shows the importance of detecting backdoors that may be injected by the supply chain-capable attacker. For the number of channels, the number of successful attackers is almost linear with the number of channels. This shows that communication channels should be watched closely. In both cases, $kSupply$ decreases following a similar trend. These results imply that communication channels of devices (e.g., SSH, Telnet) should be watched closely and backdoor detection should be performed frequently to improve the security posture against supply chain attacks.

D. Robustness Evaluation

In the previous simulations, we have shown the robustness of $kSupply$ and $kSupplier$ by testing them in different scenarios. The next step is to show the robustness of SCR calculation since it is needed to calculate $kSupply$. In these simulations, we first show that integrating SCR into $kSupply$ is important by showing the difference between two cases in which all risk factors in all supply chain vulnerabilities are set to LOW and then they are all set to HIGH. After that, we show the percentage of decrease in the number of successful attackers when each risk factor is set from HIGH to LOW. Consequently, we show the percentage of increase in the $kSupply$ metric when each risk factor is set from HIGH to LOW. Finally, we show the relationship between the number of risk factors that are set to LOW, set to HIGH, and the number of successful attackers.

Results and Implications: As it can be seen in Fig. 8a, the difference between the metrics and the number of successful category (iii) attackers increases as the number of autonomous supply chain vulnerabilities increases. This implies that enhancing the $kSupply$ metric defined in [4] with SCR becomes important as the number of autonomous supply chain vulnerabilities increases. As it can be seen in Fig.8b, for almost every risk factor, the percentage of decrease in the number of successful attackers increases. For improving the security posture and reducing the number of successful attackers origin, producer and best practices are important risk factors to focus on. As it can be seen in Fig. 8c, as each risk factor is set from HIGH to LOW, $kSupply$ increases. For improving the value of $kSupply$, origin, producer and best practices are important risk factors to focus on. Lastly, as it can be seen in Fig. 8d, as the number of risk factors that are set to LOW increases, the number of attackers decreases. However, as the number of risk factors which are set to HIGH increases, the number of successful attackers increases and this increase is faster compared to the decrease in the number of attackers when the number of risk factors with LOW increases. These simulations show that every risk factor is important and the most important three risk factors are O, BP, and P.

E. Scalability Evaluation

A power utility may want to increase its substation size, and it wants to ensure that the calculation of security metrics is not going to be impacted significantly. Therefore, this simulation aims to determine metric calculation times and MDP generation times. In metric calculation time simulations, we experimented with attack graphs with size up to 60 hosts since as detailed in [6], a typical substation contains 20 hosts in substation and bay levels. For MDP generation times, we experiment with 14, 39, 57, and 89-Bus systems.

Results and Implication: As it can be seen in Fig. 9a, even for AGs with 60 hosts, the metric calculation takes less than 1 seconds. The calculation time of $kSupplier$ grows faster than the time for $kSupply$ after 30 hosts. $kSupplier$ only changes as the power utility deploys devices from different vendors. Based on this, a power utility can utilize $kSupply$ frequently and $kSupplier$ when they deploy devices from different vendors. For the MDP generation time, as seen in Fig. 9b, it grows exponentially as the power system size increases. However, as the MDP model does not change frequently, this is tolerable. Even for the 89-Bus, the MDP generation time is around 420 seconds. These simulations demonstrate that attack graphs are scalable and the MDP models have reasonable calculation times since they are generated in an offline manner.

F. Identifying Critical Substations

In this simulation, we generate attack graphs for each bus in the bus system using a seed graph like Fig.2. After

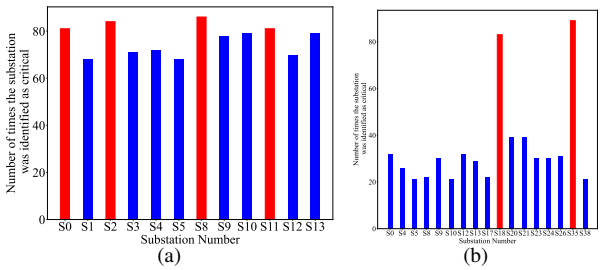


Fig. 10: Critical Substations for (a) IEEE 14-Bus (b) IEEE 39-Bus

TABLE II: Comparison of this paper with the literature on smart grid security metrics

Related Work	Model Utilized	What is Measured	Physical Impact Considered	Supply Chain Vulnerabilities Considered
[18]	MDP	Criticality of attacker states according to potential physical damage	YES	NO
[23]	Attack Graph	Mean time to compromise	NO	NO
[24]	Partially Observable MDP	Criticality of attacker states according to potential physical damage.	YES	NO
[25]	Attack Graph	Ranking Critical Assets	YES	NO
[19]	MDP	Criticality of attacker states according to potential physical damage and unserved load.	YES	NO
[4]	Attack Graph	Security postures of substations with respect to supply chain attacks.	NO	YES
[6]	Attack Graph	How well redundancy is designed from a security perspective	NO	NO
[26]	Attack Graph	Attacker Success Probability	NO	NO
This paper	Attack Graph and MDP	Security posture against supply chain attacks and substation criticalities	YES	YES

that, an MDP model is developed for each bus utilizing the corresponding attack graph models and calculating rewards using pandapower [21]. Consequently, critical substations are identified in each bus system. Experiments are repeated 100 times for each bus system to get the average execution time and critical substations. The number of times each substation in the bus system became critical out of 100 experiments is recorded.

Results and Implications: As it can be seen in Fig. 10a, Bus 0, 8 and 11 (note that bus indices are obtained from Pandapower [21]) in the IEEE 14-Bus are identified as critical substations around 80 times among 100 experiments. This shows that those substations should be the focus of security enhancement attempts in the IEEE 14-Bus. According to our experiments, the average time required to generate attack graphs, calculate metrics, generate MDP models, and identify critical substations is 24.68 seconds. Experiment results for identifying critical substations in the IEEE 39-Bus are shown in Fig. 10b. Critical substations in IEEE 39-Bus are 18 and 35. The average time required for all steps from attack graph generation to identification of critical substations is around 6 minutes.

IV. Related Work

Due to their importance for operating the smart grids, threat modeling and the calculation of security metrics have received significant attention [6], [18], [19], [23]–[26]. In [18], the authors extend the power system contingency analysis in order to consider contingencies due to cyber-attacks and develop an MDP model to identify criticality of each state with respect to potential physical damage. In [23], the authors analyze the reliability impacts of different attack scenarios and conclude that the reliability decreases as the skill levels of attackers increase utilizing attack graphs and the mean-time-to-compromise (MTTC) metric. In [24], the authors extend the work in [18] by utilizing the POMDP model that incorporates uncertainty to criticality values of each state. This allows the operators to identify critical links in the smart grid for future security improvement. In [25], several attack graph-based security metrics, which consider the cybersecurity posture and the physical impacts of attacks, are developed and verified using the IEEE 9- and 39-bus systems. In [19], the authors extend the works of [18] and [24] by considering concurrent contingencies in which two or more devices are attacked at the same time. In [4], the authors define a security metric for measuring security postures of substations against supply chain attacks but they consider each supply chain vulnerability as equivalent, which is not realistic. In [6], the authors develop a security metric that measures how well redundancy is considered from a security perspective. In [26], the authors apply an attack analysis method for the Internet of Things (IoT) utilizing graphical security models and CVSS to the smart grid and demonstrate their framework. However, to the best of our knowledge, this is the only work that considers both supply chain vulnerabilities and physical impacts of attacks for developing security metrics. Table II provides a comparative analysis between this work and other papers related to security metrics in the smart grid.

Supply chain security in the smart grid has also been studied in the literature. For instance, in [27], the authors develop a cyber threat intelligence framework to protect organizations against supply chain threats and demonstrate that it can effectively prevent them. The security of a blockchain-based identity management system with respect to supply chain attacks is studied in [28]. In [12], the authors developed a hardening framework and show that improving the security posture of IEC 61850 substations is still possible even when an operator is bound to a limited number of vendors. A Bayesian belief network is used to model cyber attacks involving supply chain vulnerabilities in [27], [29]. In [30], the authors define a multi-scale approach to facilitate the resilience of the supply chain in energy systems. However, to the best of our knowledge, this paper is the first one to quantify the security of IEC 61850 substations considering supply chain vulnerabilities.

Secure protocols that utilize blockchain and privacy-preserving data-sharing mechanisms have been designed for the smart grid. In [31], the authors develop a secure and reliable authentication protocol for smart meters and utility centers utilizing blockchain and elliptic curve cryptography. After that, they demonstrate that they demonstrate the practical security of their protocol. In [32], the authors propose a fast authentication protocol for electrical vehicle charging and then demonstrate that their protocol is more efficient in terms of communication and computation costs compared to other protocols. In [33], the authors propose a federal electrical vehicle decision-learning approach to preserve the data privacy of EV consumers and power grids. Our work differs from those in the sense that we aim to quantify the cybersecurity risk brought into smart grid substations with the existence of supply chain vulnerabilities.

V. Conclusion

In this paper, two new metrics are designed, and one existing metric is extended to measure the security posture of IEC 61850 substations against supply chain attacks. The SCR is developed by taking supply chain risk factors into account. After that, we integrated SCR into the $kSupply$ to differentiate between different supply chain vulnerabilities. Moreover, the $kSupplier$, which counts the minimum number of vendors on attack paths, is designed to overcome the cases in which $kSupply$ cannot be improved. Lastly, the MDP model is generated by leveraging attack graphs to identify critical substations regarding potential physical damage. Through simulations, it has been shown that the defined metrics effectively measure the security posture of IEC 61850 substations against supply chain attacks.

In future work, we plan to integrate those metrics into a smart grid testbed, consider more aspects of power system dynamics in the MDP model rather than just transmission line overload, improve SCR calculation by considering complexities and dependencies of devices rather than just relying on inputs from operators for risk factors, improving SCR calculation by automating it through analyzing software or firmware, utilizing blockchain for ensuring the accuracy of several risk factors (i.e., O, P, and ST), making it possible for vendors to share information related to their devices in a privacy-preserving manner for risk factors BP, UV, OU.

VI. Acknowledgement

The authors thank the anonymous reviewers for their valuable comments. The research reported in this paper is funded by the NSERC/Hydro-Quebec Thales Research Chair in Smart Grid Security and the NSERC Discovery Grant N01035.

References

[1] E. Rencelj Ling and M. Ekstedt, "Generating threat models and attack graphs based on the iec 61850 system configuration description language," in *Proceedings of the 2021 ACM Workshop on Secure and Trustworthy Cyber-Physical Systems*, pp. 98–103, 2021.

[2] E. Molina, E. Jacob, J. Matias, N. Moreira, and A. Astarloa, "Using software defined networking to manage and control iec 61850-based systems," *Computers & Electrical Eng.*, vol. 43, pp. 142–154, 2015.

[3] "SolarWinds Supply-Chain Attack." `https://www.sans.org/blog/what-you-need-to-know-about-the-solarwinds-supply-chain-attack/`. [Online; accessed 9-January-2021].

[4] O. Duman, M. Ghafouri, M. Kassouf, R. Atallah, L. Wang, and M. Debbabi, "Modeling supply chain attacks in iec 61850 substations," in *2019 IEEE Int. Conf. on Commun., Control, and Computing Technol. for Smart Grids (SmartGridComm)*, pp. 1–6, IEEE, 2019.

[5] "CVSS Version 3.1 Release." `https://www.first.org/cvss/specification-document`. [Online; accessed 23-January-2021].

[6] O. Duman, M. Zhang, L. Wang, M. Debbabi, R. Atallah, and B. Lebel, "Factor of security (fos): Quantifying the security effectiveness of redundant smart grid subsystems," *IEEE Trans. on Dependable and Secure Computing*, 2020.

[7] "4-bus, 2-generator transmission network model." `https://egriddata.org/dataset/4-bus-2-generator-transmission-network-model`. [Online; accessed 24-December-2022].

[8] S. L. Thomas and A. Francillon, "Backdoors: Definition, deniability and detection," in *Research in Attacks, Intrusions, and Defenses: 21st International Symposium, RAID 2018, Heraklion, Crete, Greece, September 10-12, 2018, Proceedings 21*, pp. 92–113, Springer, 2018.

[9] P. Ammann, D. Wijesekera, and S. Kaushik, "Scalable, graph-based network vulnerability analysis," in *Proceedings of the 9th ACM Conference on Computer and Communications Security*, pp. 217–224, 2002.

[10] O. Sheyner, J. Haines, S. Jha, R. Lippmann, and J. M. Wing, "Automated generation and analysis of attack graphs," in *Proceedings 2002 IEEE Symposium on Security and Privacy*, pp. 273–284, IEEE, 2002.

[11] L. Wang, S. Jajodia, A. Singhal, P. Cheng, and S. Noel, "k-zero day safety: A network security metric for measuring the risk of unknown vulnerabilities," *IEEE Trans. on Dependable and Secure Computing*, vol. 11, no. 1, pp. 30–44, 2013.

[12] O. Duman, L. Wang, M. Au, M. Kassouf, and M. Debbabi, "Hardening substations against supply chain attacks under operational constraints," in *2022 IEEE Power & Energy Society Innovative Smart Grid Technologies Conference (ISGT)*, pp. 1–5, IEEE, 2022.

[13] P. P. Biswas, H. C. Tan, Q. Zhu, Y. Li, D. Mashima, and B. Chen, "A synthesized dataset for cybersecurity study of iec 61850 based substation," in *2019 IEEE International Conference on Communications, Control, and Computing Technologies for Smart Grids (SmartGridComm)*, pp. 1–7, IEEE, 2019.

[14] "The Open Group Trusted Technology Forum." `https://www.opengroup.org/membership/forums/trusted-technology-forum/trusted`. [Online; accessed 9-January-2021].

[15] M. Zhang, L. Wang, S. Jajodia, A. Singhal, and M. Albanese, "Network diversity: a security metric for evaluating the resilience of networks against zero-day attacks," *IEEE Trans. on Information Forensics and Security*, vol. 11, no. 5, pp. 1071–1086, 2016.

[16] J. Boyens, A. Smith, N. Bartol, K. Winkler, A. Holbrook, and M. Fallon, "Cybersecurity supply chain risk management practices for systems and organizations," tech. rep., NIST, 2022.

[17] W. Nzoukou, L. Wang, S. Jajodia, and A. Singhal, "A unified framework for measuring a network's mean time-to-compromise," in *2013 IEEE 32nd International Symposium on Reliable Distributed Systems*, pp. 215–224, IEEE, 2013.

[18] S. Zonouz, C. M. Davis, K. R. Davis, R. Berthier, R. B. Bobba, and W. H. Sanders, "Socca: A security-oriented cyber-physical contingency analysis in power infrastructures," *IEEE Transactions on Smart Grid*, vol. 5, no. 1, pp. 3–13, 2013.

[19] P. Akaber, B. Moussa, M. Ghafouri, R. Atallah, B. L. Agba, C. Assi, and M. Debbabi, "Cases: concurrent contingency analysis-based security metric deployment for the smart grid," *IEEE Trans. on Smart Grid*, vol. 11, no. 3, pp. 2676–2687, 2019.

[20] R. S. Sutton and A. G. Barto, *Reinforcement learning: An introduction*. MIT press, 2018.

[21] L. Thurner, A. Scheidler, F. Schafer, J. H. Menke, J. Dollichon, F. Meier, S. Meinecke, and M. Braun, "pandapower - an open source python tool for convenient modeling, analysis and optimization of electric power systems," *IEEE Trans. on Power Systems*, 2018.

[22] S. Jha, O. Sheyner, and J. Wing, "Two formal analyses of attack graphs," in *Proceedings 15th IEEE Computer Security Foundations Workshop. CSFW-15*, pp. 49–63, IEEE, 2002.

[23] Y. Zhang, L. Wang, Y. Xiang, and C.-W. Ten, "Power system reliability evaluation with scada cybersecurity considerations," *IEEE Trans. on Smart Grid*, vol. 6, no. 4, pp. 1707–1721, 2015.

[24] K. R. Davis, C. M. Davis, S. A. Zonouz, R. B. Bobba, R. Berthier, L. Garcia, and P. W. Sauer, "A cyber-physical modeling and assessment framework for power grid infrastructures," *IEEE Trans. on smart grid*, vol. 6, no. 5, pp. 2464–2475, 2015.

[25] P. S. Patapanchala, C. Huo, R. B. Bobba, and E. Cotilla-Sanchez, "Exploring security metrics for electric grid infrastructures leveraging attack graphs," in *2016 IEEE Conference on Technologies for Sustainability (SusTech)*, pp. 89–95, IEEE, 2016.

[26] T. Duy Le, M. Ge, P. The Duy, H. Do Hoang, A. Anwar, S. W. Loke, R. Beuran, and Y. Tan, "Cvss based attack analysis using a graphical security model: Review and smart grid case study," in *Smart Grid and Internet of Things: 4th EAI International Conference, SGIoT 2020, TaiChung, Taiwan, December 5–6, 2020, Proceedings*, pp. 116–134, Springer, 2021.

[27] A. Yeboah-Ofori, S. Islam, and E. Yeboah-Boateng, "Cyber threat intelligence for improving cyber supply chain security," in *2019 Int. Conference on Cyber Security and Internet of Things (ICSIoT)*, pp. 28–33, IEEE, 2019.

[28] A. S. Sani, D. Yuan, K. Meng, and Z. Y. Dong, "Idenx: A blockchain-based identity management system for supply chain attacks mitigation in smart grids," in *2020 IEEE Power & Energy Society General Meeting (PESGM)*, pp. 1–5, IEEE, 2020.

[29] A. Yeboah-Ofori, S. Islam, and A. Brimicombe, "Detecting cyber supply chain attacks on cyber physical systems using bayesian belief network," in *2019 International Conference on Cyber Security and Internet of Things (ICSIoT)*, pp. 37–42, IEEE, 2019.

[30] J. H. Lambert, J. M. Keisler, W. E. Wheeler, Z. A. Collier, and I. Linkov, "Multiscale approach to the security of hardware supply chains for energy systems," *Environment Systems and Decisions*, vol. 33, no. 3, pp. 326–334, 2013.
[31] W. Wang, H. Huang, L. Zhang, and C. Su, "Secure and efficient mutual authentication protocol for smart grid under blockchain," *Peer-to-Peer Networking and Applications*, vol. 14, no. 5, pp. 2681–2693, 2021.
[32] W. Wang, Z. Han, M. Alazab, T. R. Gadekallu, X. Zhou, and C. Su, "Ultra super fast authentication protocol for electric vehicle charging using extended chaotic maps," *IEEE Transactions on Industry Applications*, vol. 58, no. 5, pp. 5616–5623, 2022.
[33] H. Huang, S. Xue, L. Zhao, W. Wang, and H. Wu, "Privacy-preserving smart energy management by consumer-electronic chips and federated learning," *IEEE Transactions on Consumer Electronics*, 2023.



Onur Duman received his M.Sc. degree from Concordia Institute for Information Systems Engineering (CIISE) in June 2016. Consequently, he received his Ph.D. degree from Concordia University, Security Research Centre in December 2023. After his Ph.D, he worked as a postdoctoral research fellow in Norway until January 2025. Since January 2025, he has been working as a Lecturer in Cyber Security and Networks at Glasgow Caledonian University in the Department of Cyber Security and Networks. Onur Duman has published several research papers in reputable venues such as TDSC, TIM, and TOSEM. His research interests include cyber-physical system security, security metrics, threat modeling, supply chain attacks, and network hardening with a focus on measuring and improving security postures of critical infrastructures.



Mohsen Ghafouri (Senior Member, IEEE) received the B.Sc. and master's degrees in electrical engineering from the Sharif University of Technology, Tehran, Iran, in 2009 and 2011, respectively, and the Ph.D. degree in electrical engineering from Polytechnique Montreal, Montreal, QC, Canada, in 2018. In 2018, he was a Researcher with CYME International, Eaton Power System Solutions, Montreal, QC, Canada. In August 2018, he joined as the Horizon Postdoctoral Fellow with Security Research Group, Concordia University, where he is currently an Associate Professor. His research interests include smart grids, power system modeling, microgrid, wind energy, and control of industrial processes.



Lingyu Wang is a full professor in the Concordia Institute for Information Systems Engineering (CIISE) at Concordia University. He held the NSERC/Ericsson Industrial Research Chair (IRC) in SDN/NFV Security between 2019 and 2024. He received his Ph.D. degree in Information Technology from George Mason University, USA, in 2006. His research interests include cloud computing security, SDN/NFV security, network security metrics, software security, and privacy. He has published seven books, six patents, and over 150 conference and journal articles, including many published at top venues such as S&P, CCS, USENIX Security, NDSS, ESORICS, PETS, ICDT, TOPS, TIFS, TDSC, JCS, etc. He has served on the editorial boards of IEEE Transactions on Dependable and Secure Computing (TDSC), Annals of Telecommunications (ANTE), and Computers & Security. He has also served as the program (co)-chair of seven international conferences, and the technical program committee member of over 150 international conferences.



Marthe Kassouf received the B.Sc. and M.Sc. degrees in Computer Engineering from École Supérieure des Ingénieurs de Beyrouth, Lebanon (1997) and from École Polytechnique de Montréal, Canada (1999), respectively. In 2008, she received the Ph.D. degree in Electrical Engineering from McGill University, Canada. Since 2008, she has been working as a researcher at the Hydro Quebec Research Center (CRHQ), where she has been contributing to the implementation of different projects aiming at the enhancement of the information and telecommunications infrastructure supporting the power grid, mainly in the areas of wireless communication systems, time synchronization and cybersecurity. Member in the Working Group 15 (WG15) of the International Electrotechnical Commission (IEC) Technical Committee (TC) 57 since 2015, she has been contributing to the development of IEC 62351 standards for the cybersecurity of power system information infrastructure. Her research interests are in telecommunication networks, time synchronization systems, power grid automation, and cybersecurity for smart grids.



Ribal Atallah (Member, IEEE) is a researcher at the Hydro-Quebec Research Institute, Montreal, QC J3X 1S1, Canada. His current research is on machine learning to protect the smart grid against cyberattacks. His interests include deep learning, reinforcement learning, and intelligent transportation systems. Atallah received a Ph.D. in information and systems engineering from Concordia University, Canada. Contact him at atallah.ribal@hydroquebec.com.



Mourad Debbabi is the Dean of the Gina Cody School of Engineering and Computer Science at Concordia University and a Full Professor at the Concordia Institute for Information Systems Engineering. He holds the Hydro-Quebec Hitachi Partnership Research Chair in Smart Grid Security with support from NSERC and PROMPT and the Hon. Concordia Research Chair Tier I in Information Systems Security. He is a founding member of the National Cybersecurity Consortium (NCC) that leads Canada's Cybersecurity Innovation Network (CSIN) program. He served on the expert committee of the Ministry of Cybersecurity and Digital Technology of the Quebec Government. He also serves/served on the boards of the Canadian Police College, PROMPT Québec, Cybereco, and Calcul Québec. He served as a member of CATAAlliance's Cybercrime Advisory Council. He is the founder and the Director of the Security Research Centre of Concordia University. Dr. Debbabi holds Ph.D. and DEA degrees in computer science from Paris-XI Orsay University, France, and a B.Eng. from Université de Constantine, Algeria. He published seven books and more than 330 peer-reviewed research articles in international journals and conferences on cybersecurity, digital forensics, smart grid security, vulnerability research, cyber threat intelligence and threat hunting, malware analysis, reverse engineering, privacy, cryptographic protocols, specification, and verification of safety-critical systems, programming languages, and type theory. He supervised the successful completion of 35 Ph.D. theses, 76 Master's theses, and 15 Postdoctoral Fellows. He served as a Senior Scientist at the Panasonic Information and Network Technologies Laboratory, Princeton, New Jersey, USA; Associate Professor at the Computer Science Department of Laval University, Canada; Senior Scientist at General Electric Research Centre, New York, USA; Research Associate at the Computer Science Department of Stanford University, California, USA; and Permanent Researcher at the Bull Corporate Research Centre, Paris, France.